

Secrets Rotation Policy

Objective This policy reduces the risk of exposed credentials while preserving application availability. No token or password may be stored in source code, Git repositories, or logs.

Recommended Rotation Periods

Item	Default Period	Notes
Vault Token	Every 6 hours	Recommended for sensitive environments. The period may be changed to 12 or 24 hours based on risk, provided that the update is automated or documented.
Database password	Every 90 days	Change it in the database first, then update Vault, restart the application, and test the connection.
JWT Secret	When needed	Changing it usually invalidates current sessions, so it should not be rotated routinely without a user re-login plan.

Safe Rotation Procedure

1. Create a new secret value and never reuse the old value.
2. Update the secret in Vault while keeping the same key name, such as VAULT_TOKEN or DB_PASSWORD.
3. Update the environment variables, then restart or redeploy the service.
4. Check /health and test login and data access before revoking the old value.
5. Revoke the old token after confirming that the new value works. Record the rotation date, but never record the secret itself.